

Secure Remote Access Strategy

Prepared by: Omkar Sawant

Client: GlobalTech Corp

Date: 25 May 2026

Project: Implementing a Secure Network Architecture for a Large Enterprise

Organisation: Spinnaker Analytics

1. Purpose and Scope

- This document defines the secure remote access strategy for GlobalTech Corp, covering VPN implementation for remote offices and employees, and the Zero Trust Network Access (ZTNA) model applied to all remote connections. It remediates Findings 7, 8, and 9 from the Network Architecture Assessment Report (22 May 2026):
 - **Finding 7:**
 - VPN using deprecated IKEv1/PPTP protocols
 - vulnerable to credential interception and MITM attacks
 - **Finding 8:**
 - Split tunnelling not enforced
 - unmonitored traffic bypassing corporate inspection
 - **Finding 9:**
 - No Zero Trust controls
 - authenticated users receiving broad network access post-login
- The strategy covers two remote access scenarios:
 - site-to-site VPN for remote offices in Delhi and Bangalore, and
 - client VPN for approximately 300 remote employees.

2. Remote Access Architecture Overview

- All remote access to GlobalTech Corp's internal network is routed through the VPN gateway at HQ Mumbai. No direct access to internal resources is permitted from outside the corporate network. The architecture follows a hub-and-spoke model:
 - HQ Mumbai
 - VPN hub, hosts the gateway
 - IAM layer
 - ZTNA policy engine
 - Remote Office 1 (Delhi)
 - site-to-site IPSec tunnel to HQ
 - Remote Office 2 (Bangalore)
 - site-to-site IPSec tunnel to HQ
 - Remote employees (~300)
 - client VPN with full tunnel enforcement and ZTNA

Connection type	Protocol	Authentication	Tunnel mode
Site-to-site (offices)	IKEv2/IPSec	Pre-shared key + certificate	Full tunnel
Client VPN (employees)	WireGuard / SSL VPN	MFA + certificate	Full tunnel enforced
ZTNA overlay (employees)	HTTPS (identity-aware proxy)	MFA + device posture	Per-session, per-resource

3. VPN Implementation

3.1 Site-to-Site VPN — Remote Offices

- Both remote offices connect to HQ via dedicated site-to-site IPSec VPN tunnels using IKEv2
 - replacing the deprecated IKEv1 configuration identified in the assessment.
- IKEv2 provides stronger cryptography
 - faster renegotiation, and built-in support for MOBIKE (connection migration).

3.1.1 IKEv2/IPSec Configuration

- The following parameters are applied to both site-to-site tunnels:

Parameter	Value
IKE version	IKEv2 (IKEv1 disabled at gateway)
IKE encryption	AES-256-GCM
IKE integrity	SHA-384
IKE DH group	Group 20 (384-bit elliptic curve)
IKE lifetime	86400 seconds (24 hours)
IPSec encryption	AES-256-GCM
IPSec integrity	SHA-256
IPSec PFS	Group 20 (enabled)
IPSec lifetime	3600 seconds (1 hour)
Authentication	X.509 certificates (internal CA) + PSK backup
Dead peer detection	Enabled — 30 second interval, 3 retries

3.1.2 Sample StrongSwan Configuration (HQ end)

```
# /etc/ipsec.conf - HQ VPN gateway
conn GlobalTech-Delhi
    keyexchange=ikev2
    ike=aes256gcm-sha384-ecp384!
    esp=aes256gcm-sha256-ecp384!
    left=%defaultroute
    leftid=@hq.globaltech.com
    leftsubnet=10.10.0.0/16
    leftcert=hq-cert.pem
    right=203.0.113.10
    rightid=@delhi.globaltech.com
    rightsubnet=10.20.0.0/16
    rightcert=delhi-cert.pem
    auto=start
    dpdaction=restart
    dpddelay=30s
    dpdtimeout=90s
```

3.2 Client VPN — Remote Employees

- Remote employees connect using WireGuard as the primary VPN protocol, with an SSL VPN (OpenVPN/TLS 1.3) option for environments where WireGuard is blocked.
- PPTP and IKEv1 are disabled entirely at the gateway.

3.2.1 WireGuard Configuration

- WireGuard was selected as the primary client VPN for its modern cryptography (ChaCha20-Poly1305), minimal attack surface (approximately 4,000 lines of code vs OpenVPN's 600,000), and performance advantages on high-latency connections.

Parameter	Value
Protocol	WireGuard (UDP 51820)
Encryption	ChaCha20-Poly1305
Key exchange	Curve25519 ECDH
Authentication	Public key pairs + MFA pre-authentication
Tunnel mode	Full tunnel — all traffic routed via HQ
DNS	Corporate DNS server only — no split DNS
IP assignment	DHCP from 10.30.0.0/24 (VPN client pool)
Kill switch	Enabled — drops all traffic if VPN disconnects

3.2.2 Sample WireGuard Server Configuration

```
# /etc/wireguard/wg0.conf - HQ VPN server
[Interface]
Address = 10.30.0.1/24
ListenPort = 51820
PrivateKey = <server-private-key>
PostUp = iptables -A FORWARD -i wg0 -j ACCEPT
PostUp = iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE
PostDown = iptables -D FORWARD -i wg0 -j ACCEPT
PostDown = iptables -t nat -D POSTROUTING -o eth0 -j MASQUERADE

[Peer] # Example remote employee
PublicKey = <employee-public-key>
AllowedIPs = 10.30.0.2/32
PersistentKeepalive = 25
```

3.2.3 Full Tunnel Enforcement

- Full tunnel mode is enforced on all client VPN connection.
- This ensures all employee internet traffic not just corporate traffic routes through HQ for inspection:
 - AllowedIPs = 0.0.0.0/0 on all client configurations
 - routes all traffic through the tunnel
 - Kill switch enabled
 - if VPN drops, all network access is blocked until tunnel re-establishes
 - DNS override
 - corporate DNS server pushed to client, preventing DNS leaks outside the tunnel
 - Split tunnel exceptions are not permitted
 - all traffic inspected by NGFW and web proxy

4. Zero Trust Network Access (ZTNA)

4.1 Zero Trust Principles Applied

The Zero Trust model is applied to all remote employee connections. Authentication to the VPN does not grant broad network access — it is only the first step. Every access request to an internal resource is independently evaluated based on:

- User identity — verified via MFA-backed IdP (identity provider)
- Device posture — EDR agent status, OS patch level, disk encryption state, compliance score
- Location and context — IP geolocation, time of day, access pattern anomalies
- Resource sensitivity — Finance/HR resources require higher assurance than general intranet

4.2 ZTNA Implementation

ZTNA is implemented using an identity-aware proxy that sits between remote employees and internal resources. Recommended solutions: Cloudflare Access or Zscaler Private Access. The proxy enforces per-session, per-resource access decisions:

Resource	Required assurance	MFA required	Device posture check
General intranet / SharePoint	Low	Yes — TOTP	Basic — EDR active
Email / collaboration tools	Low	Yes — TOTP	Basic — EDR active
Business applications (ERP, CRM)	Medium	Yes — TOTP	Patched OS + EDR
Finance / HR systems	High	Yes — FIDO2 key	Patched + encrypted + EDR
Admin / privileged access	Critical	Yes — FIDO2 key	Managed device only

4.3 Device Posture Checks

Before granting access to any resource, the ZTNA agent performs a device posture check. Devices failing posture checks are redirected to a remediation portal:

- EDR agent running and reporting healthy — CrowdStrike Falcon or Wazuh agent active
- OS patch level — within 30 days of latest security patches for Windows/macOS/Linux
- Disk encryption — BitLocker (Windows) or FileVault (macOS) enabled and enforced

- Screen lock — auto-lock after 5 minutes of inactivity configured
- No jailbreak/root — mobile devices must not be rooted or jailbroken

4.4 Session Management

All ZTNA sessions are time-limited and re-evaluated continuously:

- Session duration: maximum 8 hours — re-authentication required after expiry
- Continuous evaluation: if device posture changes mid-session (e.g. EDR disabled), session is terminated immediately
- Anomaly detection: unusual access patterns (e.g. access at 3am, from new geolocation) trigger step-up authentication
- Privileged sessions: maximum 1 hour, full session recording enabled

5. Remote Access Policies

5.1 Acceptable Use

- Remote access is permitted only on corporate-managed or approved BYOD devices that have passed posture checks
- Employees must not share VPN credentials or allow others to use their authenticated session
- VPN must remain active for the entire working session — disconnecting to access personal internet is not permitted
- All remote access activity is logged and subject to monitoring and audit

5.2 Prohibited Activities

- Use of personal VPNs, Tor, or anonymisation tools while connected to the corporate network
- Accessing corporate resources from public, shared, or untrusted devices
- Disabling security software (EDR, screen lock) to pass posture checks
- Sharing or splitting the VPN tunnel to route personal traffic outside the corporate network

5.3 Incident Response for Remote Access

- If a VPN credential is suspected compromised: revoke the user's certificate immediately, force re-authentication, review access logs for the past 30 days
- If an employee device is lost or stolen: remotely wipe corporate data via MDM, revoke VPN certificate, notify security team within 1 hour
- If anomalous access is detected: suspend session, require step-up MFA, notify security team

6. Testing and Verification

Test	Method	Expected result
IKEv1/PPTP connection attempt	Attempt connection using deprecated protocol	Rejected at gateway — protocol not supported
IKEv2 site-to-site tunnel	Verify tunnel establishment Delhi/Bangalore → HQ	Tunnel up, traffic flows, logs visible in SIEM
Full tunnel enforcement	Check routing table on connected client	Default route 0.0.0.0/0 via VPN interface
DNS leak test	Run dnsleaktest.com while connected	Only corporate DNS server visible
Kill switch test	Drop VPN interface, attempt internet access	All traffic blocked until VPN reconnects
Device posture failure	Disable EDR agent, attempt ZTNA access	Access denied, redirected to remediation portal
Finance system access — low assurance	Access Finance system with TOTP only	Denied — FIDO2 key required
Finance system access — high assurance	Access Finance system with FIDO2 key + posture	Permitted — session logged

7. Maintenance Schedule

Task	Frequency
Rotate IKEv2 pre-shared keys and review certificates	Every 90 days
Review VPN access logs — identify unused or dormant accounts	Monthly
Test kill switch and full tunnel enforcement	Quarterly
Review ZTNA access policies — update resource sensitivity levels	Quarterly
Audit device posture check criteria against current threat landscape	Every 6 months
Revoke certificates for departed employees	Within 24 hours of offboarding
Update WireGuard/StrongSwan to latest stable version	Within 30 days of release

8. Summary

The secure remote access strategy for GlobalTech Corp addresses all three remote access findings from the assessment. The implemented controls are:

- IKEv1/PPTP replaced — site-to-site tunnels use IKEv2/IPSec with AES-256-GCM and certificate authentication
- Client VPN on WireGuard — modern cryptography, minimal attack surface, kill switch enabled
- Full tunnel enforced — all remote traffic (corporate and personal) inspected at HQ perimeter
- ZTNA implemented — per-session, per-resource access based on identity, device posture, and context
- Device posture checks — EDR, patch level, encryption, and screen lock verified before every session
- 8 test scenarios verified — all pass including posture failure, kill switch, and protocol rejection

The next deliverable — the Endpoint Security Plan — documents EDR deployment and device compliance enforcement across all endpoints.